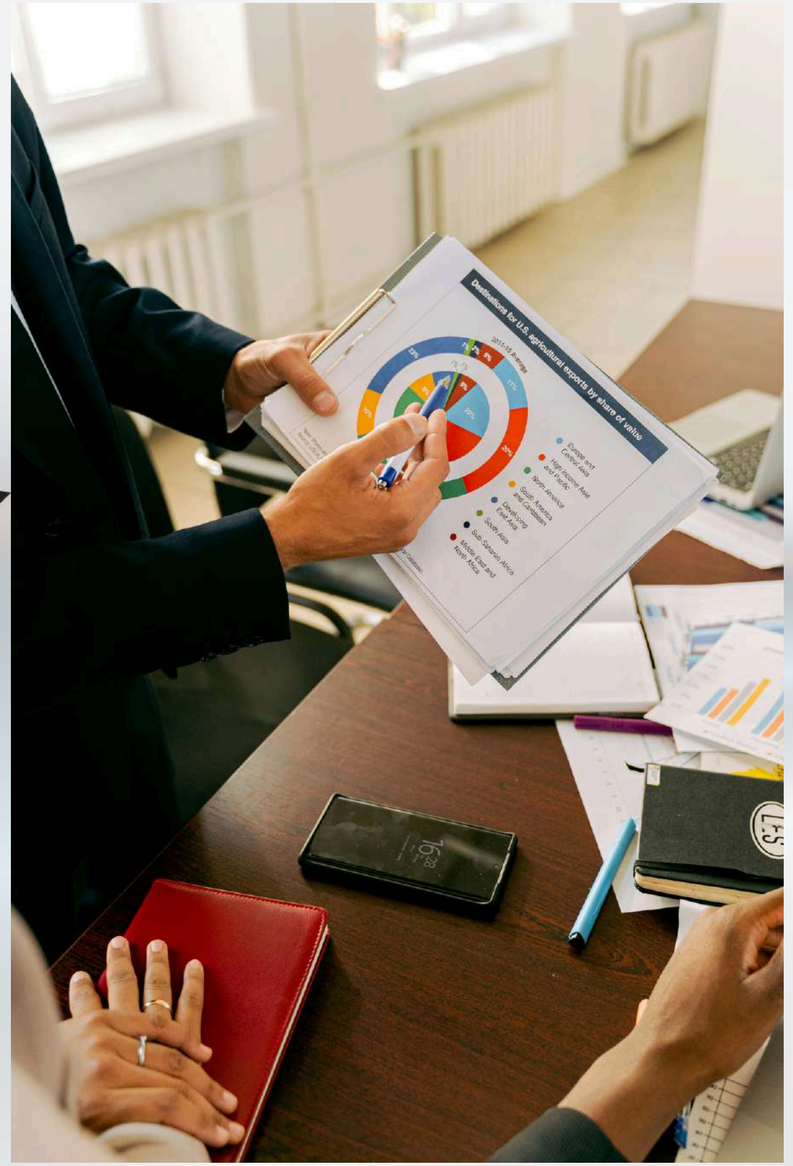
DYNAMIC BIZ IT SOLUTIONS

ISO/IEC 27001:2022

ISMS IMPLEMENTATION PROPOSAL



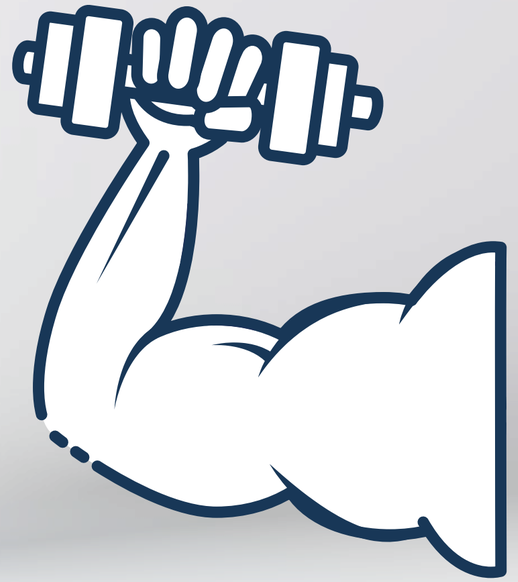
Executive Summary

- Dynamic Biz handles sensitive client and financial data
- Current security measures exist but lack formal ISMS structure
- Proposal: Implement ISO/IEC 27001:2022 ISMS
- Outcome:
- Improved security posture
- Regulatory compliance
- Increased customer trust

Organization Overview

- Medium-sized IT service provider (~300 employees)
- Services:
  - Software development
  - Customer support
  - Managed IT services
- Key assets:
  - Client data
  - Source code
  - Financial records

Current Security Posture



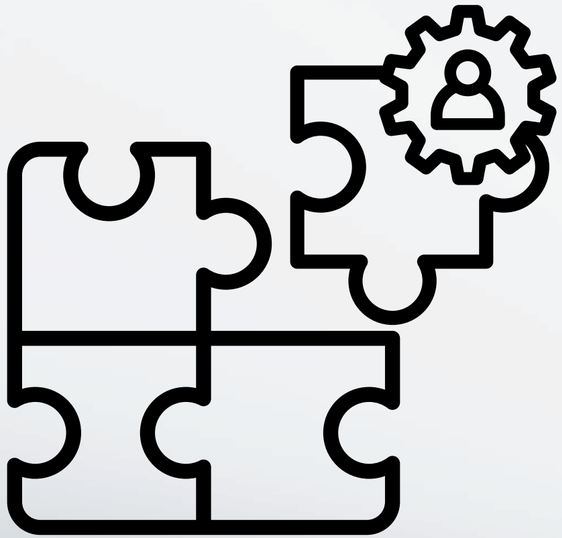
Strengths:

- Role-Based Access Control (RBAC)
- Multi-Factor Authentication (MFA)
- Encryption (AES-256, TLS)
- Security awareness platform

Weaknesses:

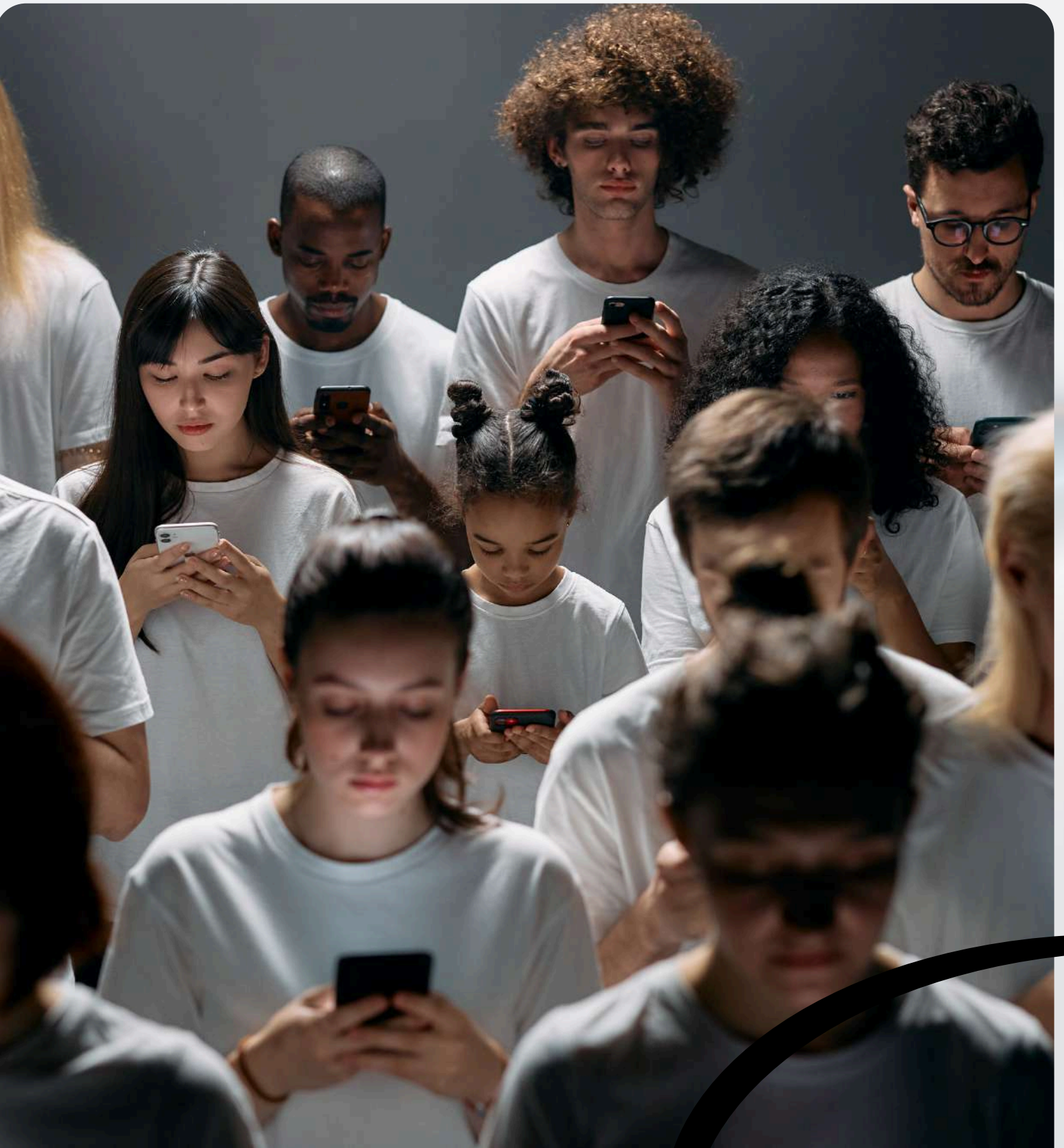
- No formal ISMS framework
- No structured risk management
- Limited leadership involvement

★★★★★



Gap Analysis Findings

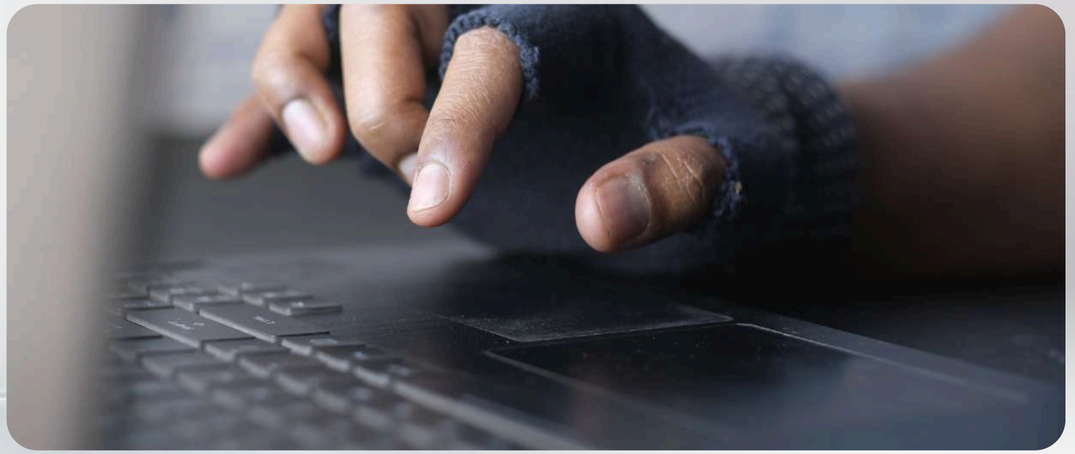
- Missing ISMS scope & governance
- No formal risk assessment methodology
- Lack of incident response & supplier management
- No internal audit or performance evaluation
- Weak business continuity planning



Key Risks Identified

- Phishing attacks → Client data exposure
- Unauthorized access → Source code theft
- Data breaches → Financial loss
- DoS attacks → Service disruption
- Insider threats → Data misuse

Risk Mitigation Strategy



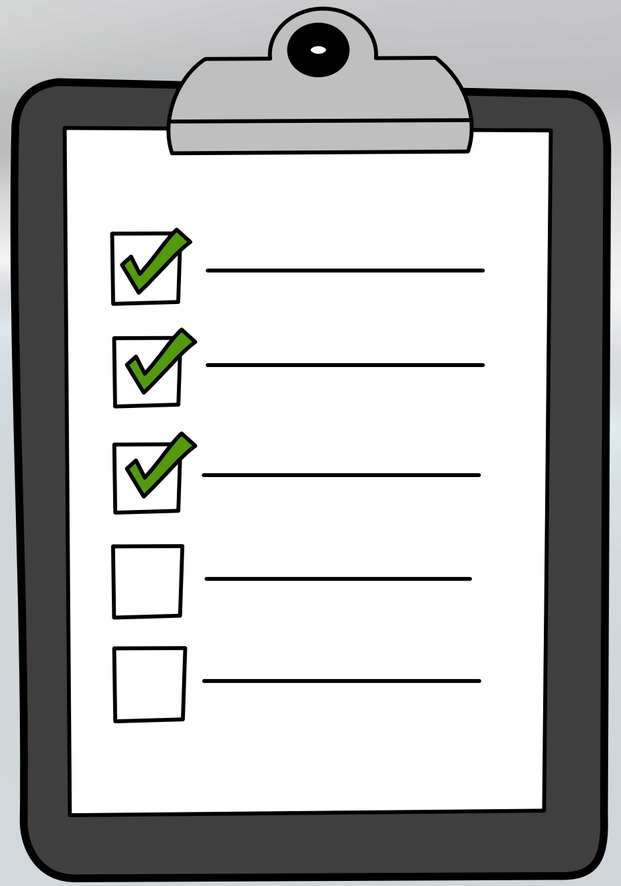
- Implement MFA across all systems
- Deploy email filtering & phishing simulations
- Encrypt sensitive data (AES-256)
- Introduce Web Application Firewall (WAF)
- Deploy Data Loss Prevention (DLP) tools

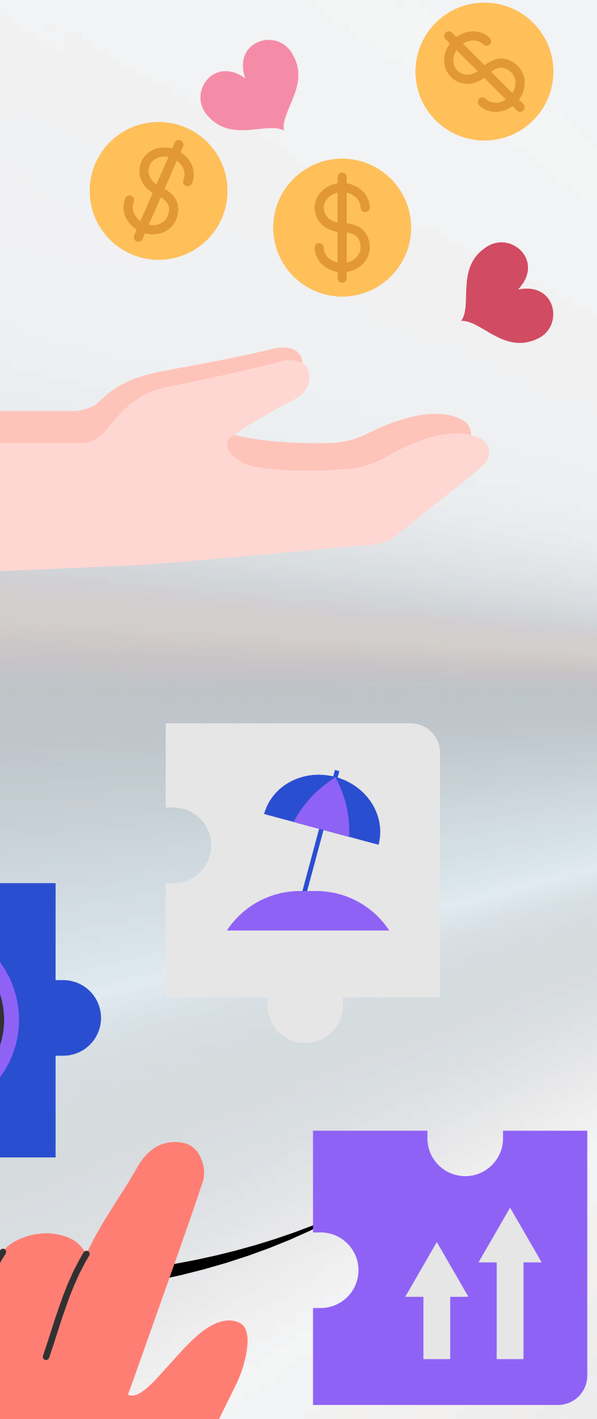
ISMS Implementation Roadmap

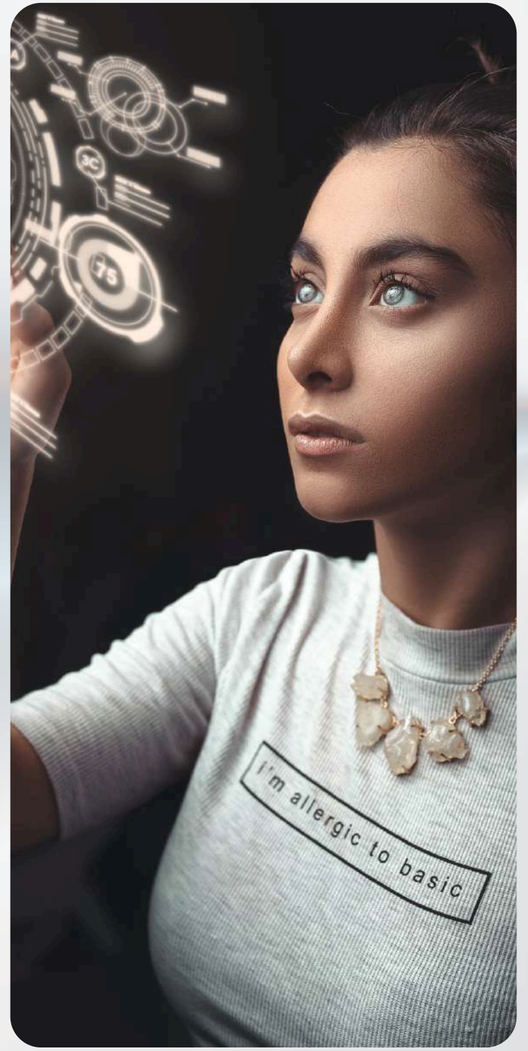
- Phase 1: Define Scope & Policies
- Phase 2: Conduct Risk Assessment
- Phase 3: Implement Controls (Annex A)
- Phase 4: Monitor & Audit ISMS
- Phase 5: Continuous Improvement

Statement of Applicability (SoA)

- Controls selected based on risk assessment
- Examples:
- Access Control (A.9)
- Cryptography (A.10)
- Incident Management (A.16)
- Some controls partially implemented → improvement needed

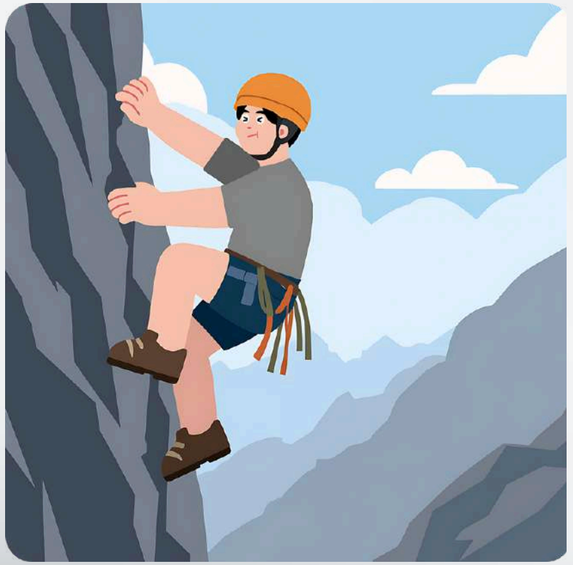






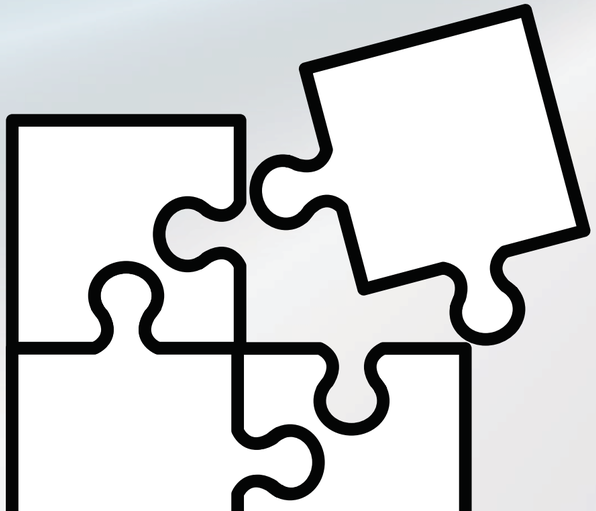
Business Benefits

- Stronger data protection
- Compliance with GDPR / PDPA
- Reduced risk of cyber incidents
- Improved customer confidence
- Competitive advantage in IT industry



Challenges & Considerations

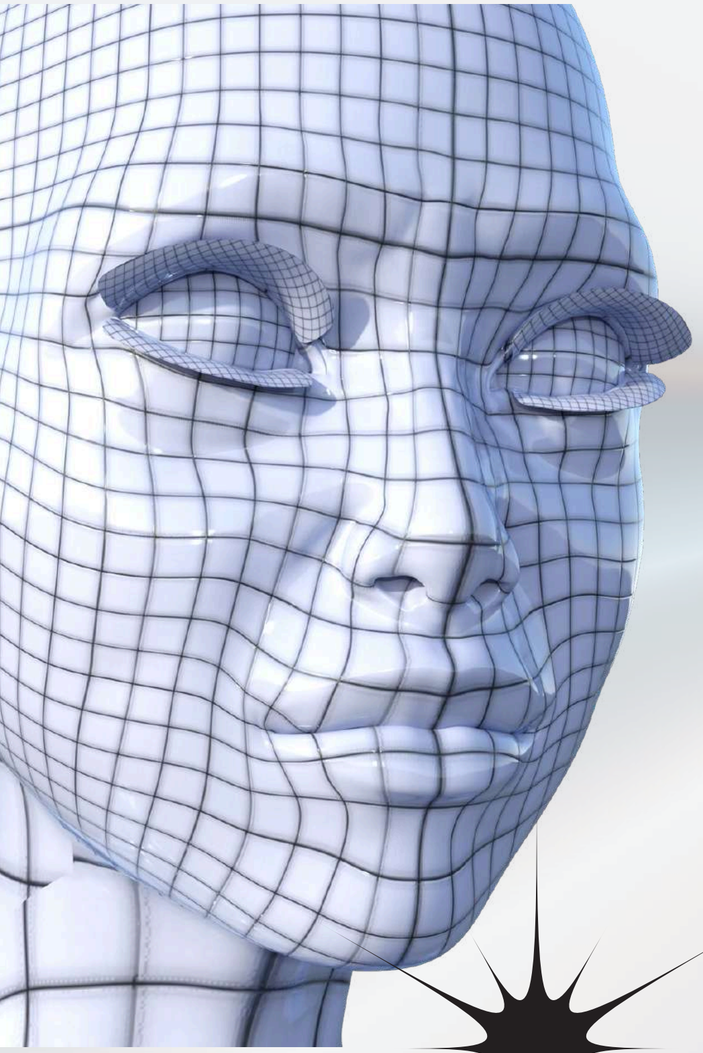
- Resource allocation (time, cost, staff)
- Employee awareness & training
- Continuous monitoring required
- Integration with existing systems



Conclusion & Recommendation

- ISMS is critical for business sustainability
- Current gaps pose significant risks
- ISO 27001 implementation is strongly recommended
- Next step: Begin Phase 1 immediately

ANY QUESTIONS?



Thank You

Stay Safe, Stay Smart